NICCS 候选签名算法安全性证明评估

以 Aigis-Sig+ 为基准的四方案对比分析

Jy L

2026 年 10 月 10 日

摘要

本报告以 Aigis-Sig+ 的安全性证明（NICCS 格签名中最为完整和严谨的）为基准，对比评估 BiT-128 和 COMPASS-SIG-128 的证明结构，并以 NEV（NICCS KEM，证明方法论权威）作为跨家族参考。核心发现：(1) Aigis 的 “entropic rejection sampling” 技术将统计 min-entropy 需求转化为计算假设（AMLWE），是证明紧性的关键创新；(2) BiT 的证明存在结构性缺口（双模挑战分叉引理未完整执行、经典 ROM 仅证明），与我们实证完成的密钥恢复攻击一致；(3) COMPASS 的证明省略了核心归约（仅引用 BBD+23），但其 w_1 一致性检查在实证中消除了回归信号——证明中该检查被 “仅进入损失项 p” 处理，实际上是一个未被充分刻画的接受条件化机制。

1 评估框架

1.1 证明质量分级标准

维度	A 级	B 级	C 级
安全模型	QROM + ROM	仅 ROM	仅 ROM，启发式量子论证
归约紧性	近紧（常数因子）	多项式损失	未量化
证明完整性	全部写出	核心引用外部	关键步骤省略
假设标准性	全部标准或充分论证	有新假设但合理化	新假设，论证不充分
具体安全	CoreSVP + MATZOV	CoreSVP	单一模型

2 Aigis-Sig+：基准证明

2.1 证明架构

Aigis-Sig+ 采用 FSwA（Fiat–Shamir with Aborts）架构，基于三个独立定理：

- **定理 3**（SUF-CMA → UF-NMA + CUR）：7 步游戏跳跃，核心创新是将 $w = Ay$ 替换为 $w = Ay + e$（引理 4：分布等价），然后用 AMLWE 假设将 w 的伪随机性替代统计 min-entropy。

- **定理 4**（UF-NMA → AMLWE + SelfTargetAMSIS）：利用 $2\gamma_2$ 重缩放擦除 HighBits 丢失的低位信息。
- **定理 5**（CUR → AMSIS，标准模型）：两个接受转录之差给出 AMSIS 解，范数 $2\gamma_3$（而非 $4\gamma_2$）。

2.2 关键创新：Entropic Rejection Sampling

Aigis 的核心贡献

传统 Dilithium 系证明要求 w_1 具有高 min-entropy（统计要求），这迫使 $\gamma_1 > \gamma_2$ 并增大签名。Aigis 通过**更严格的拒绝条件**（$r \in S'^k_{\gamma_2-\beta_2-1}$，额外 -1），使得当 $e \in S^k_{\beta_1}$ 时 HighBits(Ay+e) = HighBits(Ay) 恒成立——从而允许在证明中将 w 替换为 AMLWE 伪随机值。这是 "entropic" 的含义：用计算伪随机性替代统计熵。

2.3 证明中的假设与缺口

1. SelfTargetAMSIS 是假设而非紧归约（QROM 中直接假设）
2. 拒绝概率 $\tilde{p}$ 用启发式估计（非精确）
3. 查询预算假设 $q_S, q_H \leq 2^{80}$
4. $\mathrm{AMLWE}_{\alpha_1,\beta_1}$（$B_2$ 项）的微小性是 "信念" 而非定量估计
5. $\epsilon \leq 2^{-264}$ "可推导" 但未在正文展开

3 BiT-128：与实证攻击的一致性

3.1 证明结构

BiT 在经典可编程 ROM 中证明 SUF-CMA，使用三引理结构：(1) UF-CMA → UF-NMA（5 步游戏跳跃，KLS18 风格）；(2) UF-NMA → BimodalSelfTargetMSIS（紧归约）；(3) SUF-CMA → UF-CMA（MSIS，引用 forking lemma）。

3.2 关键缺口与攻击面

证明缺口 ↔ 攻击实证

1. **双模挑战**（$z_0 = y_0 + \varepsilon c$）：证明假设拒绝采样后 z 的分布与秘密无关（完美 ZK），但双模符号 ε 是逐签名**共享潜变量**。我们的攻击通过 z_0 推断 ε（96.2% 准确率），然后用它对齐 z_1 通道恢复 s_0。证明未考虑 z_0 与 z_1 之间的条件相关性。
2. **Forking lemma 引用未执行**：SUF 归约中的 forking 仅一句话带过（"challenge c remains unchanged by the forking lemma"），未正式处理强伪造（不同挑战 c）的情况。
3. **仅经典 ROM**：量子安全性用 Grover 搜索启发式处理，无 QROM 归约。

结论：BiT 的证明结构有其可取之处（完全写出的游戏跳跃、紧的 SelfTargetMSIS 归约），但其 ZK 论证忽略了双模符号引入的条件信息泄露。我们的攻击（4M 签名完整密钥恢复 + 20/20 伪造）直接利用了这一缺口。

4 COMPASS-SIG-128：接受条件化的未被刻画效应

4.1 证明结构

COMPASS 采用 BBD+23 风格的可编程 RO 证明，声称 QROM 损失 $\leq 2^{-980}$。但**核心归约未在文档中复现**（仅引用 “closely follows [BBD+23]”）。

4.2 w_1 一致性检查：证明盲区

实证发现与证明的张力

COMPASS 的签名循环包含 w_1 一致性检查：验证 decompose$(w - cs_2 + ct_0)$ 的高位等于原始 w_1。在证明中，这个检查被处理为 “仅影响损失项 p （非中止概率）”——即只影响签名效率，不影响安全性。

但我们的实证（三尺度、两种独立路径）表明：这一检查的接受概率依赖秘密 (s_2, t_0)，**条件化了发布分布，完全消除了回归信号**（corr ≈ 0，σ 精确吻合定律但无信号分量）。这不是安全性漏洞（反而增强了安全性），而是证明中**未被刻画的效应**：拒绝采样不仅影响效率，还改变了发布的 (c, z) 对的联合分布。

方法论启示：FS-aborts 族的安全性证明应显式分析接受条件对 (c, z) 联合分布的影响，而不仅仅将其视为 “效率参数”。Aigis 的 entropic rejection sampling 正确处理了这一点（将拒绝与伪随机性替代结合），而 COMPASS 的证明省略了这一分析。

5 NEV：跨家族参考（KEM）

NEV 是 NTRU 族 KEM，采用 FO 变换 + 显式拒绝。其证明方法论（标准模型 OW-CPA → ROM/QROM IND-CPA → IND-CCA）与签名族不同，但在严谨性上与 Aigis 相当：

- **紧性**：ROM CCA 损失 $q_D + 2q_{H_2}$（线性），QROM 损失 $O(\sqrt{q_{H_2}})$
- **新假设**：sspRLWE（子集和奇偶 RLWE）——有 DRLWE 归约（$\sqrt{3}$ 噪声膨胀），但仅在 Gaussian 噪声下证明
- **缺口**：binomial 噪声情形用 Rényi 散度 “可扩展” 但未写出；压缩变体依赖独立性假设

NEV 的证明标准（完整写出 + 双模型 + 显式损失界）是签名族应参照的。

维度	Aigis-Sig+	BiT	COMPASS	NEV (KEM)
模型	QROM+ROM	仅 ROM	ROM+QROM 损失	QROM+ROM
证明完整性	完整写出	完整写出	**核心省略**	完整写出
归约紧性	近紧 ($\times 2$)	多项式	未复现	线性/$\surd$
拒绝处理	Entropic+AMLWE	完美 ZK(忽略条件)	损失项 p(未刻画)	解密失败 δ
新假设	SelfTargetAMSIS	BimodalST-MSIS	SelfTargetMSIS$_R$	sspRLWE
具体安全	CoreSVP+MATZOV	CoreSVP	CoreSVP+Shell-CVP	CoreSVP+MATZOV
实证攻击	未测试	**已攻破**	**信号消除**	不适用

6 四方案对比矩阵

7 系统性结论

7.1 NICCS 安全性证明的共同模式

1. **架构统一**：全部格签名采用 FSwA + SelfTargetMSIS 变体 + MLWE 密钥不可区分。这是 Dilithium 遗产。
2. **证明完整性差异大**：Aigis 完整写出 28 页附录证明；COMPASS 仅引用外部文献。这在提交评审中应有不同的权重。
3. **拒绝采样的证明处理是关键分水岭**：
   - Aigis：将拒绝与伪随机性替代结合（entropic RS）$\rightarrow$ 紧证明
   - BiT：假设完美 ZK（忽略条件信息）$\rightarrow$ 被攻击
   - COMPASS：视为效率参数（未刻画条件化）$\rightarrow$ 意外增强安全性

7.2 对 universal 模型的启示

我们的攻击实证与安全性证明的对照揭示了：

实证与证明的互补关系

- BiT 的证明缺口 $\leftrightarrow$ 我们的完整密钥恢复（证明忽略的条件信息正是攻击通道）
- COMPASS 的证明盲区 $\leftrightarrow$ 我们的信号消除发现（证明未刻画的接受条件化反而阻止了攻击）
- Aigis 的 entropic RS $\leftrightarrow$ 尚未测试（框架可测试：接受条件是否也消除了回归信号?）

这表明**安全性证明和实证攻击是互补的**：证明关注最坏情况归约，攻击关注平均情况信息；两者交叉验证才能给出完整的安全评估。

7.3 建议

1. **对评审**：要求所有 FSwA 方案显式分析拒绝条件对 (c, z) 联合分布的影响（Aigis 的 Lemma 4 是标准做法）

2. **对参数选择：**Aigis 的 “更严格拒绝换取更紧证明” 范式值得推广——用少量效率换取证明完整性

3. **对我们的框架：**将 “接受条件化效应” 正式化为 assay 的一个输出维度——区分 “信号为零因为掩码太宽” 和 “信号为零因为接受条件化消除”